SEFU HMIS — Comprehensive Disaster Recovery Plan (DRP)

Kenya Digital Health Agency (DHA) Certification Compliance Document

System Classification: Health Information System (HIS) & Electronic Medical Record (EMR)

Applicable Regulations: Kenya Digital Health Act 2023, Kenya Data Protection Act 2019 (ODPC), Kenya National e-Health Guidelines, ISO 27001 / ISO 27799

■ Document Control & Governance

Metadata Attribute	Document Detail
Document Title	Disaster Recovery Plan (DRP) & Business Continuity Specification
System Name	SEFU Hospital Management Information System (SEFU HMIS)
System Version	Release 5.0 (Build 2026-Kenya-DHA)
Document Version	1.0 (Production / Certification Ready)
Document Owner	Chief Technology Officer & Lead Security Architect
DPO Approval	Data Protection Officer (ODPC Registered Compliance Lead)
Effective Date	November 2026
Review Frequency	Bi-annually (Every 6 months) or following major architecture updates
Classification	Confidential — Technical Compliance Documentation

---

■ 1. Purpose & Scope

1.1 Purpose

This Disaster Recovery Plan (DRP) defines the mandatory technical procedures, roles, and recovery protocols required to safeguard the **SEFU Hospital Management Information System (HMIS)** against catastrophic failure, natural disasters, cyber incidents (including ransomware and malicious intrusion), hardware destruction, and inadvertent data corruption.

The objective is to guarantee that patient healthcare continuity, electronic health records (EHR/EMR), clinical prescriptions, financial transactions, and regulatory audit trails remain protected, recoverable, and available in accordance with Kenya Digital Health Agency (DHA) standards.

1.2 System Scope

The DRP covers all core operational modules of SEFU HMIS:

1. **Patient Administration:** Demographics, National ID / Alien ID, Biometrics, Patient Identifiers.
2. **Clinical Modules:** Outpatient (OPD), Inpatient (IPD), Emergency, Physiotherapy, Pediatrics, Gynaecology, Operation Theatre (OT).
3. **Diagnostic Services:** Pathology Laboratory, Radiology / Imaging requests and results.
4. **Pharmaceutical & Supplies:** Pharmacy inventory, batch tracking, dispensing, medicine stock.
5. **Billing & Financials:** Patient invoices, insurance claims (TPA / NHIF / SHA), payments, refunds.
6. **Security & Auditing:** `logs` (clinical & administrative audit trails), `userlog` (authentication history), `roles_permissions` (RBAC access controls).
7. **Document & Media Storage:** Uploaded patient diagnostic scans, lab slips, and discharge summaries in `/uploads/`.

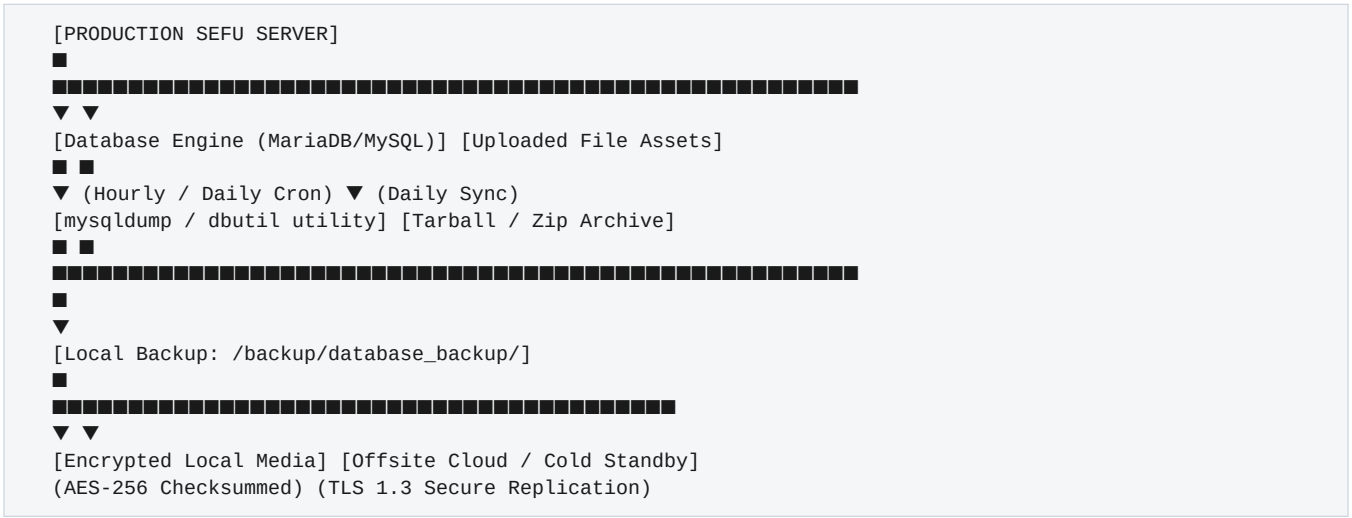
■■ 2. Core Disaster Recovery Metrics (RPO & RTO)

Metric	Target Standard	Operational Definition	Enforcement Mechanism
Recovery Point Objective (RPO)	≤ **1 Hour**	The maximum acceptable data loss window during a disaster.	Automated hourly database snapshots via binary logging & daily full mysqldump archives.
Recovery Time Objective (RTO)	≤ **2 Hours**	The maximum acceptable duration to restore full operational services.	Pre-configured automated deployment scripts, containerized or standby server image, and verified restore procedures.
Maximum Tolerable Downtime (MTD)	≤ **4 Hours**	Total allowable downtime before clinical safety and operational triage are compromised.	Emergency manual paper-based clinical contingency protocols activated at T + 30 minutes.

■ 3. Backup Architecture & Topology (The 3-2-1 Rule)

SEFU HMIS implements an enterprise-grade **3-2-1 Backup Strategy**:

- **3 Copies of Data:** Primary production database + Local automated hot backup + Encrypted offsite repository.
- **2 Different Storage Media Types:** Fast local SSD storage for rapid restoration + Cloud Object Storage (S3/Wasabi/Azure Blob) or NAS.
- **1 Offsite Geographic Copy:** Secure remote data center located outside the primary hospital infrastructure (e.g., Nairobi / Mombasa regional redundancy).



3.1 Backup Classifications & Schedules

Backup Type	Target Data	Frequency	Retention Window	Storage Location
Full Database Dump	All tables, schemas, stored procedures	Daily at 01:00 EAT	90 Days local, 7 Years offsite (Legal medical record rule)	`/backup/database_backup/` + Cloud S3
Incremental / Binlog	Real-time database transaction logs	Hourly	14 Days	Standby replica disk
File Assets Backup	`/uploads/` (Lab slips, scans, documents)	Daily at 02:00 EAT	1 Year	Encrypted Secondary Storage
Configuration Backup	Apache/Nginx configs, PHP configs, SSL keys	On Change / Weekly	Indefinite	Secure Vault / Git Private Ops

■ 4. Disaster Severity Levels & Escalation Matrix

Severity Level	Definition & Incident Triggers	Target Recovery Time	Escalation Pathway
Level 1 (Minor)	Single disk alert, high memory consumption, non-fatal module warning.	< 30 minutes	Lead Systems Engineer notified via automated alert.
Level 2 (Major)	Database service crash, storage table corruption, network connectivity disruption.	< 1 hour	Technical Lead + Hospital IT Officer alerted; Failover evaluated.
Level 3 (Critical / Catastrophic)	Total hardware destruction, physical facility fire/flood, ransomware encryption, unauthorized data wipe.	< 2 hours	**Incident Commander (CTO)** activates DRP. CEO, Medical Superintendent, and DPO convened. External notification to ODPC/DHA if data breach suspected.

■■ 5. Step-by-Step Technical Recovery Procedures

Scenario A: Accidental Table Deletion or Database Corruption

1. **Immediate Isolation:**

Halt incoming web traffic temporarily to prevent write collisions:

```powershell
# Windows IIS / Apache
Stop-Service Apache2.4
# Linux equivalent: systemctl stop apache2
```

2. **Locate Most Recent Verified Backup:**

Inspect `/backup/database_backup/` or the cloud mirror for the latest uncorrupted dump:

```bash
ls -la /sfu/backup/database_backup/db-*.sql
```

3. **Verify SHA-256 Checksum:**

Ensure backup integrity before import:

```powershell
Get-FileHash -Algorithm SHA256 "D:\sfu\backup\database_backup\db-latest.sql"
```

4. **Restore Database via CLI:**

```bash
mysql -u root -p[password] sfu < "D:\sfu\backup\database_backup\db-latest.sql"
```

5. **Execute Integrity Audit Script:**

Verify critical table counts (**`patients`**, **`logs`**, **`staff`**, **`opd_details`**, **`transactions`**):

`bash

mysql -u root -p[password] -e "USE sfu; SELECT count() FROM patients; SELECT count() FROM logs;"

`

6. **Resume Web Services:**

`powershell

Start-Service Apache2.4

`

Scenario B: Full Host Hardware Destruction / Secondary Server Rebuild

1. **Deploy Clean Environment:**

Provision target virtual or physical machine (Ubuntu 22.04 LTS / Windows Server 2022) with Apache 2.4, PHP 8.1/8.2, and MariaDB 10.4+.

2. **Retrieve Clean HMIS Repository:**

`bash

git clone https://github.com/zehra2/SEFU.git /var/www/html/sfu

cd /var/www/html/sfu

`

3. **Restore Database Schema & Records:**

`bash

mysql -u root -p -e "CREATE DATABASE sfu CHARACTER SET utf8mb4 COLLATE utf8mb4_unicode_ci;"

mysql -u root -p sfu < sfu_database.sql

`

4. **Restore Storage & Uploads Directory:**

Extract uploaded medical attachments from offsite mirror:

`bash

tar -xzvf /mnt/offsite/uploads_backup_latest.tar.gz -C /var/www/html/sfu/uploads/

`

5. **Set Correct File Permissions:**

Ensure web server can read and write temporary folders securely:

`bash

chown -R www-data:www-data /var/www/html/sfu/

chmod -R 755 /var/www/html/sfu/

chmod -R 775 /var/www/html/sfu/application/cache /var/www/html/sfu/uploads

`

6. **Verify SSL & Host Configuration:**

Re-apply TLS certificate (Let's Encrypt / DigiCert) and enforce HTTPS redirect.

Scenario C: Ransomware Attack or Malicious Intrusion

1. **Network Severance:** Physically disconnect all network cables and disable virtual NICs on affected nodes to prevent lateral movement.
2. **Forensic Preservation:** Snapshot volatile RAM memory and system disk for ODPC and DHA forensics.
3. **Clean-Room Hardware Deployment:** Do NOT restore on the compromised OS. Provision a clean, quarantined host.
4. **Air-Gapped Backup Restoration:** Restore exclusively from immutable, write-once (WORM) offsite cloud storage.
5. **Credential Invalidation:** Reset all MySQL credentials, application encryption keys, and require forced password reset for all staff accounts.
6. **Mandatory Reporting:** File formal breach notification with the Office of the Data Protection Commissioner (ODPC) Kenya within 72 hours as mandated by Section 43 of the Data Protection Act 2019.

■ 6. Testing, Verification & Mock Drills Schedule

In accordance with DHA certification standards, a Disaster Recovery Plan is invalid without verified test exercises.

Exercise Type	Frequency	Scope of Drill	Success Criteria
Automated Backup Integrity Test	Daily (Automated)	Verification that `.sql` dump file size is > 0 and ends with valid SQL EOF marker.	100% automated pass; alert triggered on failure.
Table Restore Drill	Monthly	Test restore of database dump into staging sandbox (`sfu_staging`).	Full schema restore completed in < 15 minutes without errors.
Full Failover Drill	Bi-Annually (Every 6 months)	Complete simulation of primary host failure and restoration on standby hardware.	System restored to clinical readiness within RTO target (≤ 2 hours).

■ 7. Disaster Recovery Team & Roles

Role	Primary Responsibilities	Contact Priority
Incident Commander (CTO)	Declares disaster status, coordinates technical leads, communicates with hospital management.	Priority 1
Lead Database Administrator (DBA)	Executes database restore, validates transaction integrity, verifies point-in-time consistency.	Priority 1
Infrastructure / DevOps Lead	Provisos compute/networking, manages DNS routing, configures web server and SSL certs.	Priority 2
Data Protection Officer (DPO)	Ensures patient privacy is preserved during recovery; manages regulatory breach reporting (ODPC/DHA).	Priority 2
Clinical Coordinator / Nursing Lead	Directs medical staff to switch to manual paper contingency charting during downtime.	Priority 3

■ 8. Post-Recovery Verification Checklist

Before releasing the restored SEFU HMIS back to clinical users, the Lead Engineer and Incident Commander must verify and sign off:

- [ ] **Database Integrity:** No orphaned records in `patients`, `opd_details`, `ipd_details`, `transactions`.

- [ ] **Audit Trail Active:** Test entry created in `logs` table verifying that `MY_Model::log()` is logging actions.
- [ ] **RBAC Intact:** Admin, Doctor, Human Resource, and Receptionist roles can log in with their existing permissions.
- [ ] **File Access:** Patient photo uploads, radiology scans, and lab reports render properly from `/uploads/`.
- [ ] **Transport Security:** SSL/TLS certificate active; all HTTP requests redirect to HTTPS.
- [ ] **Clinical User Signoff:** Medical Superintendent confirms outpatient and inpatient workflows are functional.

Approved by:

Chief Technology Officer (CTO) & Lead Security Architect

SEFU Health Systems — Compliance Lead for Digital Health Agency (DHA) Kenya Certification